Capitolo I

Identificazione di furto (copia) di dati riservati tra analisi stocastica ed eventi sentinella

1. Premessa

Dalle fasi iniziali di progettazione ed organizzazione aziendale sino alla vendita di beni o alla fornitura di servizi, ogni azienda assume una serie di scelte tecniche e decisioni aziendali che rappresentano un tale valore economico che è indubbio il vantaggio di cui godrebbero i concorrenti qualora dovessero entrarne a conoscenza. Oltre alle informazioni strettamente legate al core business, ulteriori informazioni quali preventivi, condizioni economiche, database di clienti e fornitori, manuali, campagne pubblicitarie e piani di marketing sono altre informazioni che rappresentano degli asset intangibili di un'azienda.

La protezione di questo insieme di dati riservati riveste un ruolo fondamentale per l'impresa, specie in tempi di crisi economica, quando ogni errore può costare caro alla sopravvivenza della stessa. Quando la condotta riguarda l'appropriazione di file svincolati dal loro supporto, non sussiste il reato di furto, per carenza di tipicità[1]. La copia di

[1] Cfr. Cassazione Penale n. 44840 del 26 ottobre 2010. Il caso vede come soggetto un impiegato che si era procurato copia di file aziendali contenenti dati e offerte commerciali poco prima di dare le dimissioni. In un secondo momento, l'uomo aveva prelevato e spostato i dati riservati sul proprio indirizzo privato di posta elettronica, utilizzandoli successivamente a vantaggio di un'azienda concorrente della quale nel frattempo era diventato co-amministratore. Secondo i giudici, la riproduzione non autorizzata del materiale non può essere considerata come furto poiché non si verifica la perdita del possesso del bene da parte del legittimo proprietario: i dati e le informazioni presenti nei file non possono rientrare nel concetto di "cosa mobile".

file aziendali e il loro riutilizzo successivo alle dimissioni da parte del dipendente in attività concorrenziale integra il reato di cui all'art. 622 C.P. ; la mera copia di file contenenti dati riservati di un'azienda non costituisce formalmente un "furto" quando i dati sono solo copiati e restano nella disponibilità dell'azienda.

Ogni impresa detiene dei segreti frutto di lavoro, esperienza e ricerca maturati durante l'attività imprenditoriale: la maggior parte delle imprese però si rende conto della loro importanza soltanto quando il segreto è stato svelato e, solo in questo frangente, capisce di aver posseduto qualcosa che, nella sua immaterialità, deteneva un valore che meritava di essere protetto con maggiore attenzione. Senza una corretta gestione dei rapporti tra azienda e lavoratore, la protezione dei segreti industriali rischia di scontrarsi con i diritti dei lavori.

Nel caso pratico proposto, l'indagine di informatica forense mira ad evidenziare come sia possibile ricostruire i tempi e i modi in cui un particolare evento – nel caso specifico la copia di dati – si è verificato: correlando opportunamente i timestamp ed alcuni "eventi sentinella" è possibile comprendere quando si è verificato un evento e, possibilmente, chi è l'autore.

Il presente articolo si propone di illustrare delle tecniche con le quali è possibile analizzare sistemi informatici aziendali utilizzati in maniera impropria da dipendenti o collaboratori i quali, avendo libero accesso ai sistemi informatici, hanno avuto la possibilità di estrarre copia di dati riservati. L'uso della timeline consente di ovviare, seppure ad un livello di dettaglio inferiore, all'assenza di log sulle operazioni di accesso ai file.

2. Aspetti giuridici relativi alla tutela e al controllo del lavoratore

2.1. *Tutela del lavoratore*

Le informazioni trattate da un lavoratore sul posto di lavoro possono riguardare, oltre all'attività lavorativa, la sfera personale e la vita privata, proprie e di terzi. La linea di confine tra questi ambiti, come

Visto l'utilizzo dei dati riservati a vantaggio di una società concorrente, la Corte ha classificato l'illecito come rivelazione di segreto professionale o di segreto industriale.

affermato dalla Corte europea dei diritti dell'uomo, può essere tracciata a volte solo con difficoltà.

Il luogo di lavoro è una formazione sociale nella quale va assicurata la tutela dei diritti, delle libertà fondamentali e della dignità degli interessati garantendo che, in una cornice di reciproci diritti e doveri, sia assicurata l'esplicazione della personalità del lavoratore e una ragionevole protezione della sua sfera di riservatezza nelle relazioni personali e professionali.

Non a caso, nell'organizzare l'attività lavorativa e gli strumenti utilizzati, diversi datori di lavoro hanno prefigurato modalità d'uso che, tenendo conto del crescente lavoro in rete e di nuove tariffe di traffico forfettarie, assegnano aree di lavoro riservate per appunti strettamente personali, ovvero consentono usi moderati di strumenti per finalità private.[2]

2.2. *Il controllo del lavoratore*

Le risorse aziendali sono concesse al dipendente in mero uso dal datore di lavoro, il quale pertanto ha il diritto di controllare l'uso che ne viene fatto al fine di verificare eventuali abusi. Le modalità di esecuzione dei controlli attuabili dal datore di lavoro sui dipendenti sono regolate dalla sin dal 1970 con la Legge 20 maggio 1970, n. 300 (Statuto dei lavoratori). In particolare, l'art. 4 disciplina il controllo a distanza dei lavoratori[3].

[2] Garante per la protezione dei dati personali. Le linee guida del Garante per posta elettronica e internet. Gazzetta Ufficiale n. 58 del 10 marzo 2007. Registro delle deliberazioni del. n. 13 del 1 marzo 2007. *http://www.garanteprivacy.it/web/guest/home/docweb/-/docweb-display/docweb/1387522*.

[3] Art. 4 Legge 20 maggio 1970, n. 300 – Statuto dei lavoratori.
É vietato l'uso di impianti audiovisivi e di altre apparecchiature per finalità di controllo a distanza dell'attività dei lavoratori. Gli impianti e le apparecchiature di controllo che siano richiesti da esigenze organizzative e produttive ovvero dalla sicurezza del lavoro, ma dai quali derivi anche la possibilità di controllo a distanza dell'attività dei lavoratori, possono essere installati soltanto previo accordo con le rappresentanze sindacali aziendali, oppure, in mancanza di queste, con la commissione interna. In difetto di accordo, su istanza del datore di lavoro, provvede l'Ispettorato del lavoro, dettando, ove occorra, le modalità per l'uso di tali impianti.
Per gli impianti e le apparecchiature esistenti, che rispondano alle caratteristiche di cui al secondo comma del presente articolo, in mancanza di accordo con le rappresentanze sindacali aziendali o con la commissione interna, l'Ispettorato del lavoro provvede entro un anno dall'entrata in vigore della presente legge, dettando all'occorrenza le prescrizioni per l'adeguamento e le modalità di uso degli impianti suddetti.

Anche se l'intenzione originaria del Legislatore era quella di prevenire il controllo mediante sistemi di videosorveglianza tipo telecamere, la norma è estendibile ad altri tipi di controlli tecnicamente possibili in virtù dell'evoluzione tecnologia: registrazione delle attività svolte su un sistema informatico, screenshot generati ad intervalli periodici dell'output a monitor e keylogger sono alcuni di questi esempi.

Diverso è invece è l'aspetto che concerne il controllo dei dati contenuti in un sistema informatico in uso ad un lavoratore: la Sezione Lavoro della Cassazione, con sentenza 23 febbraio 2012, n. 2722, si è espressa in tema di controllo delle informazioni contenute all'interno di email: il divieto di controllo dell'email del lavoratore viene meno se il controllo si verifica ex post. La sentenza si riferisce ad un licenziamento per giusta causa di un lavoratore che, sfruttando la propria posizione aziendale, si era reso responsabile della divulgazione di email destinate a terzi rispetto al datore di lavoro, comunicando notizie di natura riservata e approfittando del contenuto per eseguire alcune operazioni dalle quali aveva tratto vantaggio personalmente. Secondo la Corte, poiché il controllo dell'email non rappresenta sorveglianza, non sussiste alcuna violazione allo Statuto dei Lavoratori in tema di controlli a distanza dei lavoratori. Tale attività di analisi forense rappresenta un diritto del datore di lavoro atto a tutelare il proprio patrimonio.

Per la Cassazione il caso è diverso da quello tutelato dall'articolo 4 dello Statuto dei Lavoratori: l'attività di controllo sulle strutture informatiche aziendali da parte del datore di lavoro "prescinde dalla pura e semplice sorveglianza sull'esecuzione della prestazione", ma è "diretta ad accertare la perpetrazione di eventuali comportamenti illeciti (poi effettivamente riscontrati)". Il controllo è dunque consentito se non è focalizzato sull'esatto adempimento delle obbligazioni discendenti dal rapporto di lavoro, bensì destinato ad accertare un comportamento che pone in pericolo la stessa immagine dell'azienda presso terzi.

2.3. *L'informativa preventiva*

Il D. Lgs. 196/2003 (Codice in materia di dati personali), all'art. 114, ribadisce che nell'ambito della controllo a distanza sul posto di lavoro, resta valido quanto stabilito dal sopra citato art. 4 dello Statuto dei lavoratori.

L'onere di indicare in modo chiaro quali siano le modalità di utilizzo degli strumenti messi a disposizione del dipendente grava sul datore di lavoro: nell'informativa fornita devono essere individuate le modalità con le quali vengono effettuati i controlli e in che misura.

A tal fine risulta utile l'adozione di un disciplinare interno, redatto in modo chiaro e senza formule generiche, da aggiornare periodicamente e da pubblicizzare adeguatamente (verso i singoli lavoratori, nella rete interna, mediante affissioni sui luoghi di lavoro...).

Sul tema, con la delibera n. 13 del 1 marzo 2007, il Garante propone che a seconda dei casi andrebbe ad esempio specificato:

- se determinati comportamenti non sono tollerati (ad esempio, la consultazione di determinate categorie di siti, il download di software o musica su reti peer-to-peer...);
- in quale misura è consentito utilizzare, anche per ragioni personali, servizi di posta elettronica o di rete, anche solo da determinate postazioni di lavoro o caselle oppure ricorrendo a sistemi di webmail, indicandone le modalità e l'arco temporale di utilizzo (ad esempio, fuori dall'orario di lavoro, durante le pause o consentendone un uso moderato anche nel tempo di lavoro);
- quali informazioni sono memorizzate temporaneamente (ad esempio, file di log di navigazione) e chi vi può accedere legittimamente;
- se e quali informazioni sono eventualmente conservate per un periodo più lungo, in forma centralizzata o meno (anche per effetto di copie di back up, della gestione tecnica della rete o di file di log);
- se, e in quale misura, il datore di lavoro si riserva di effettuare controlli in conformità alla legge, anche saltuari o occasionali, indicando le ragioni legittime - specifiche e non generiche - per cui verrebbero effettuati (anche per verifiche sulla funzionalità e sicurezza del sistema) e le relative modalità (precisando se, in caso di abusi singoli o reiterati, vengono inoltrati preventivi avvisi collettivi o individuali ed effettuati controlli nominativi o su singoli dispositivi e postazioni);

- quali conseguenze, anche di tipo disciplinare, il datore di lavoro si riserva di trarre qualora constati che la posta elettronica e la rete Internet sono utilizzate indebitamente;
- le soluzioni prefigurate per garantire, con la cooperazione del lavoratore, la continuità dell'attività lavorativa in caso di assenza del lavoratore stesso (specie se programmata), con particolare riferimento all'attivazione di sistemi di risposta automatica ai messaggi di posta elettronica ricevuti;
- se sono utilizzabili modalità di uso personale di mezzi con pagamento o fatturazione a carico dell'interessato;
- quali misure sono adottate per particolari realtà lavorative nelle quali debba essere rispettato l'eventuale segreto professionale cui siano tenute specifiche figure professionali;
- le prescrizioni interne sulla sicurezza dei dati e dei sistemi.

2.4. *Una procedura di investigazione in contesto aziendale*

Una volta fornita una informativa preventiva e dettagliata, la procedura di controllo[4] dell'uso delle risorse di comunicazione può essere strutturata in sei fasi:

1. analisi aggregata (cioè anonima) del traffico di rete e rilevazione della tipologia di utilizzo (es: 10% email, 30% file audio, 40% accesso a risorse estranee alle mansioni);
2. emanazione di una circolare con la quale si invitano i dipendenti a "rientrare nei ranghi", annunciando un ulteriore controllo;
3. ripetizione del controllo, analizzando le tipologie di impiego da parte delle singole strutture aziendali e verifica dei risultati;
4. emanazione, se i risultati sono ancora non accettabili, di una ulteriore circolare che annuncia controlli personalizzati;
5. nuova analisi anonima per verificare la situazione;
6. controllo individualizzato in caso di permanere di una situazione non conforme.

[4] Cfr. Perri P., *Controllare l'internet sul luogo di lavoro*, 2006. *http://www.ictlex.net/?p=535*.

3. Aspetti tecnici: il caso del furto (copia) di dati

3.1. *Timestamp dei file*

A differenza delle indagini tradizionali basate ad esempio su documenti cartacei, nel campo dell'informatica i dati sono accompagnati da rilevazioni temporali che consentono a posteriori di ricostruire con un grado di approssimazione piuttosto preciso gli eventi che si sono verificati: ad ogni file gestito all'interno di un file system[5] sono associati dei valori relativi alle date di creazione del file, di ultimo accesso e di ultima modifica su quel file system.

Il timestamp è il dato aggregato <data,ora> e rappresenta l'istante in cui un file è stato modificato per l'ultima volta (M, modification), acceduto per l'ultima volta (A, access) e creato (C, creation): le tre sigle costituiscono l'acronimo MAC con il quale (MAC time) spesso si indica il timestamp[6]. Più precisamente:

- il timestamp di ultima modifica indica il momento più recente in cui il file ha subito delle modificazioni ed è stato salvato, ovvero scritto su disco, direttamente dall'utente o da un programma in maniera automatica;
- il timestamp di ultimo accesso indica il momento in cui il file è stato trattato (visualizzato, aperto, stampato...);
- il timestamp di creazione è il momento in cui il file è stato creato sul file system in cui è salvato.

Un timestamp può essere visto come un semplice log di un'operazione compiuta su un file.[7]

Per comprendere le differenze, si considerino i seguenti esempi[8]:

[5] Un file system è una parte del sistema operativo che mantiene informazioni relative all'allocazione fisica dei dati sul disco, ottimizzando lo spazio allocato e gestendo file e cartelle (nome, collocazione fisica dei bit che lo compongono sul disco...).

[6] L'acronimo MAC (Modified, Created, Accessed) relativo al timestamp non è da confondere con l'indirizzo MAC (acronimo di Media Access Control) che caratterizza le interfacce di rete.

[7] Cfr. Koen R., Olivier M., "The Use of File Timestamps in Digital Forensics", in *ISSA 2008*, Johannesburg, South Africa, July 2008.

[8] Cfr. Chow K.P., Law F., Kwan M., Lai P, "The Rules of Time on NTFS File System", in *Second International Workshop on Systematic Approaches to Digital Forensic Engineering*, 2007, pp. 71-85. Cfr. Willassen S.Y., "Timestamp evidence correlation by model based clock hypothesis testing", in *Proceedings of the 1st international conference on Forensic applications and techniques in telecommunications, information, and multimedia and workshop (e-Forensics '08)*, ICST, 2008.

- su un file system FS1, in data 01/01/2011 viene salvato alle ore 01:00 un file F1 relativo un documento di testo appena digitato:
  $C_{F1} = M_{F1} = A_{F1} = <01/01/2011,01:00>$
- in data 02/02/2011 alle ore 02:00 il file F1 viene aperto, letto e chiuso:
  $C_{F1} = M_{F1} = <01/01/2011,01:00>$
  $A_{F1} = <02/02/2011,02:00>$
- in data 03/03/2011 alle ore 03:00 il file F1 viene aperto, modificato, salvato e chiuso:
  $C_{F1} = <01/01/2011,01:00>$
  $M_{F1} = A_{F1} = <03/03/2011,03:00>$
- in data 04/04/2011 alle ore 04:00 il file F1 viene copiato su un file system FS2 (chiamiamo F2 il file salvato su FS2):
  $C_{F1} = <01/01/2011,01:00>$
  $M_{F1} = M_{F2} = <03/03/2011,03:00>$
  $A_{F1} = C_{F2} = A_{F2} = <04/04/2011,04:00>$

Come si può notare, la data di creazione non rappresenta necessariamente la data di prima generazione del file, bensì l'istante in cui il file trova "vita" su un file system. Si noti altresì che pertanto possibile che un file abbia data di ultima modifica precedente alla data di creazione.

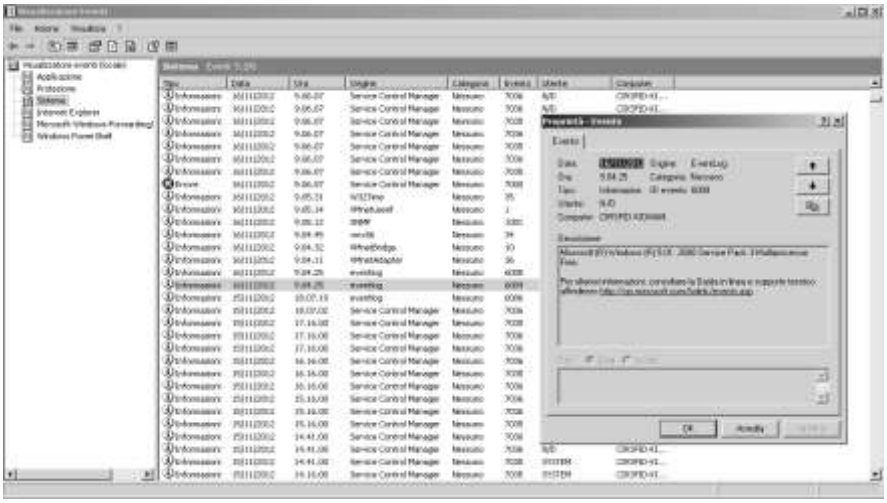
3.2. *Timeline, eventi e log*

Ordinando opportunamente i timestamp di tutti i file presenti in un file system, sia in chiaro che cancellati, è possibile studiare l'utilizzo del sistema informatico in particolari momenti storici. Tale analisi si basa pesantemente su concetti matematici di natura statistica con i quali è possibile identificare delle situazioni anomale che si sono verificate in un sistema informatico anche a distanza di tempo.

Una timeline contiene tutti i timestamp di creazione, ultima modifica e ultima lettura di tutti i file (in chiaro e cancellati) censiti dal file system, ordinati cronologicamente. Rappresenta un vero e proprio giornale di bordo di tutte le operazioni che hanno coinvolto i file salvati sulla memoria di massa che sono state eseguite sul sistema informatico.

Una versione più completa di timeline può includere altre informazioni temporali: infatti, oltre alle informazioni relative ad accesso, creazione e modifica, ad ogni file sono associate ulteriori metadati quali, ad esempio, la data e l'ora di ultima stampa di un documento, la prima data e ora di creazione del documento stesso (che non necessariamente coincide con la data di creazione del file sul file system), l'autore dell'ultima modifica.

Inoltre, ulteriori informazioni temporali sono memorizzate dal sistema operativo, il quale si occupa di registrare un insieme di eventi di vario tipo (di sistema, di sicurezza...) con data e ora: di seguito, un esempio di evento di data e ora di accensione di un sistema Windows XP con Service Pack 3.[9]

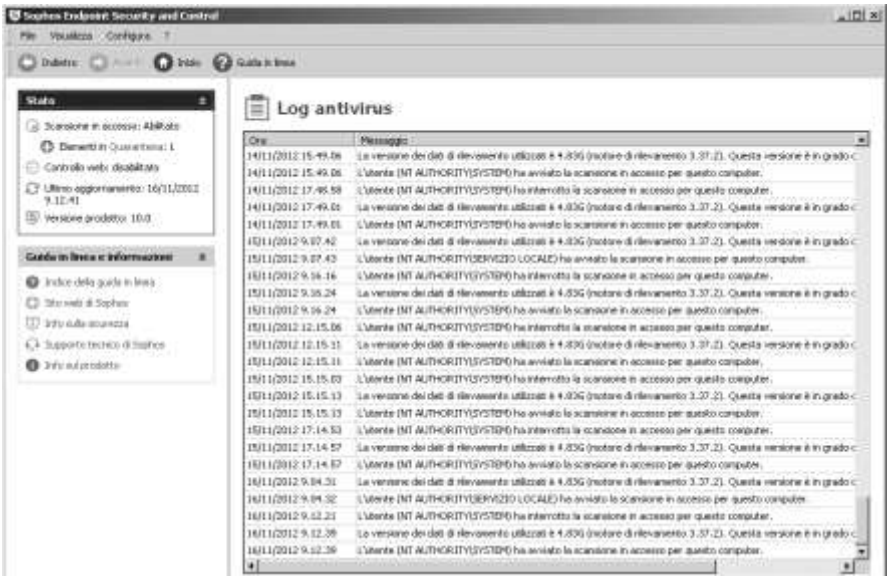


Oltre al sistema operativo, anche i vari programmi in esecuzione possono gestire la registrazione degli eventi in maniera più o meno dettagliata: di seguito, un esempio di log del software antivirus Sophos.

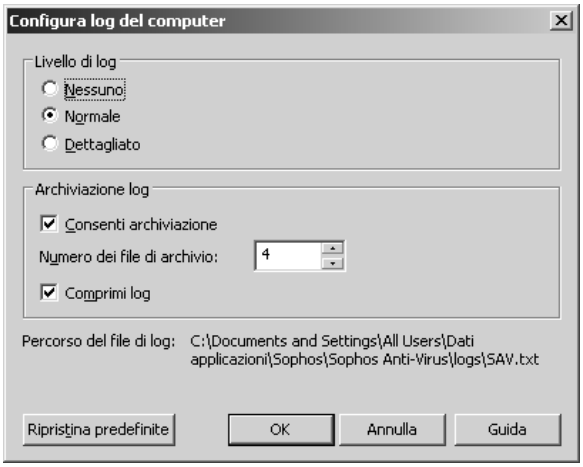
[9] I sistemi Microsoft Windows registrano le informazioni relative all'avvio e all'arresto del sistema utilizzando i seguenti identificativi:

- l'evento 6005 indica l'avvio del servizio "Registro eventi";
- l'evento 6006 indica l'arresto regolare del sistema e del servizio "Registro eventi";
- l'evento 6008 indica un arresto anomalo del sistema;
- l'evento 6009 viene registrato durante ogni avvio e indica la versione del sistema operativo, la versione del service pack e altre informazioni pertinenti per il sistema di generazione.

Fonte: *http://support.microsoft.com/kb/196452*.



Sia nei sistemi operativi che nei software applicativi dove vengono generati i log, esiste la possibilità di personalizzare il livello di dettaglio e le modalità di conservazione dei file di log: di seguito, l'esempio del software antivirus Sophos.



3.3. *Timeline, eventi e log come strumenti di analisi forense*

Sin dal 2000, Farmer e Venema[10] hanno studiato la possibilità di ricostruire gli eventi che si sono verificati sul sistema utilizzando i timestamp.

L'analisi di timeline deve assicurarsi in primo luogo che i dati temporali siano reali ed accurati. Può infatti capitare che l'orologio di sistema non sia correttamente sincronizzato con l'ora reale, che il file system non memorizzi un timestamp dettagliato ma solo la data, oppure che le informazioni temporali siano state volutamente alterate.

Riguardo allo scostamento dell'orologio di sistema, ovvero della differenza tra l'ora reale e l'ora del sistema[11], la problematica assume notevole importanza nel momento in cui il sistema sottoposto ad analisi deve essere messo in correlazione, su base temporale, con altri sistemi o, più in generale, a situazioni in cui il fattore temporale è determinate (ad esempio, per stabilire un alibi). Tuttavia, i moderni sistemi, perennemente connessi alla rete, vengono frequentemente aggiornati anche quando lo scostamento è dell'ordine di pochi secondi.[12]

Ai fini del presente articolo, il problema dell'affidabilità dei timestamp non viene affrontato dettagliatamente e si assume che tali vali siano affidabili.

Analizzando i picchi di accesso ai file è possibile identificare l'evento "lettura massiva di file", ossia di quell'evento in cui numerosi file sono letti in rapida successione temporale.

Pertanto nel momento in cui si verifica una copia massiva, ossia numerosissimi file vengono copiati da un file system (ad esempio, di un pc) a un altro (ad esempio, di un disco esterno), risulterà che in un breve arco di tempo moltissimi file sono letti dal file system sorgente e creati e letti sul file system destinazione.

Quindi, con il termine "lettura massiva di file" va inteso un evento preliminare alla "copia massiva di file", atteso che "la lettura massiva di file" è condizione necessaria alla "copia massiva di file".

Sulla base di queste considerazioni, l'analisi forense di un sistema sul quale si sospetta sia stata eseguita una copia massiva di file ha co-

[10] Cfr. Farmer D., Venema W., *Forensic discovery*. Addison Wesley, 2004.

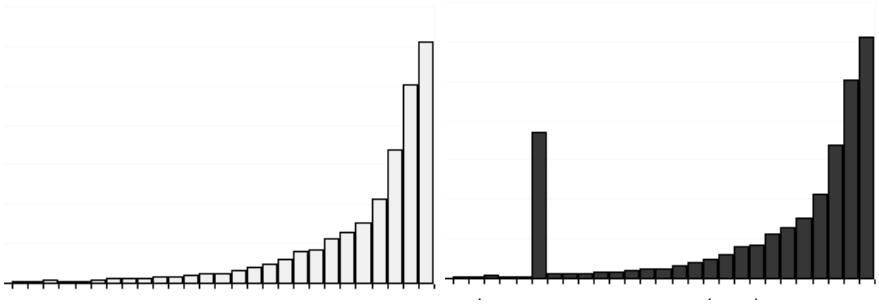
[11] A tal proposito, una delle best practice in tema di individuazione del reperto informatico è "appena individuato un sistema informatico, determinare se c'è discrepanza tra data e ora del sistema e data e ora reale".

[12] Il problema dello scostamento orario tra più sistemi resisterebbe comunque per questioni di fuso orario: tuttavia anche in questo caso è possibile risolvere la problematica comparando tutti gli orari sul tempo universale (UTC).

me primo obiettivo la ricerca di tale evento sentinella sul sistema oggetto di accertamento.

La rilevanza di tale dato assume maggiore rilevanza nella circostanza in cui tale evento sentinella si verifica in occasione della restituzioni del sistema informatico utilizzato dal dipendente al proprio datore di lavoro.

I due grafici seguenti misurano il numero di file acceduti nel tempo: in una situazione normale (a sinistra) i file sono acceduti di frequente di recente mentre in presenza di un evento tipo lettura massiva di file (a destra) si registra un picco di accessi. Questo genere di analisi può essere compiuto sia a livello di intero file system che a livello di singole cartelle.



3.4. *La copia di file*

Come già spiegato, l'operazione di copia di un file si compone di due fasi: lettura del file dalla posizione originaria e la scrittura del file nella posizione di destinazione. Tipicamente, in contesto aziendale nel quale si verifica il "furto" di dati (o più in generale, la rivelazione di segreto industriale) la destinazione è un supporto di memorizzazione diverso, pertanto sul sistema analizzato si trova traccia solo delle operazioni di lettura mentre manca l'informazione relativa all'operazione di scrittura.

L'unica informazione disponibile è relativa alla lettura sequenziale in rapida successione temporale di un elevato numero di file, che presenta compatibilità con l'operazione di copia massiva di file.

Tuttavia, tale circostanza è insufficiente a sostenere da sola che i file così identificati sono stati sottoposti ad attività di copia massiva:

sono numerosi infatti i casi in cui la data di ultimo accesso di un file viene alterata in maniera automatica.

Un tipico esempio di alterazione automatica di data di ultima lettura è la scansione di un file system (o di una cartella, suo sottoinsieme) con software antivirus[13] il quale, per verificare la liceità di un file, provvede all'apertura del file stesso. Un altro caso di modifica automatica di un insieme di file si verifica utilizzando dei tool di backup "artigianali" che prevedono banalmente copia dei file senza preservarne i timestamp.

Altra attività che genera alterazione automatica delle date di ultima lettura è la funzione "Cerca" dei sistemi Microsoft Windows: quando l'utente avvia una ricerca tra i file presenti sul file system utilizzando specifiche parole chiave ha la possibilità di cercare tra i nomi dei file o tra i contenuti dei file; nel secondo caso, il sistema operativo procede all'apertura dei vari file al fine di verificare se le keyword prescelte sono presenti all'interno del file preso in esame.

3.5. *Acquisizione dei dati*

Le osservazioni a proposito dell'alterazione di date in fase di copia, sia sul file system sorgente che sul file system destinazione, valgono non solo per il dipendente che ha indebitamente copiato dati riservati ma anche per chi conduce attività di analisi.

Tipicamente, quando l'azienda scopre di essere vittima di un furto (o copia) di dati, coinvolge – nei casi migliori – un tecnico del settore ICT per tentare di recuperare il maltolto e per condurre una prima indagine. È tuttavia evidente come in una situazione di questo tipo si finisce per compromettere, spesso irreparabilmente, la scena criminis: poiché una mera copia di file non rappresenta una copia forense, in quanto non gode delle proprietà di inalterabilità ed integrità dei dati, la prima attività da svolgere in situazioni anche solo dubbie è la creazione di un'immagine bit-stream.[14]

[13] A proposito di alterazioni automatiche da parte di antivirus, è doveroso precisare che i software antivirus moderni tendono a mantenere inalterate le date di ultimo accesso ai file.

[14] Cfr. Costabile G., "Computer forensics e informatica investigativa alla luce della legge n. 48 del 2008", in *Ciberspazio e diritto*, volume 11, n. 3, pp. 499 e ss. La copia forense (o bit-stream) è una copia 1 a 1, bit per bit, del supporto di memoria in un altro dispositivo di memorizzazione. La copia deve essere, a livello logico, perfettamente identica al dispositivo originale. In tal modo vengono preservati non solo i dati, ma anche lo spazio libero sul disco, i me-

Per la natura volatile e facilmente alterabile del dato digitale, sui dati acquisiti deve essere applicato un sigillo elettronico[15] per consentire di autenticare le prove[16]. Tecnicamente, allo stato dell'arte attuale, la procedura che permette di applicare un sigillo elettronico è la seguente:

- calcolo dell'hash dei dati contenuti nel supporto acquisito (a garanzia di integrità),
- applicazione di marca temporale (a garanzia del tempo in cui è stata effettuata l'acquisizione) e firma digitale (al fine di dimostrare chi tecnicamente ha svolto l'attività) all'impronta hash.

3.6. *Gli eventi sentinella*

Nel caso del presente articolo, con il termine "evento sentinella" si fa riferimento ad un'informazione - non necessariamente in formato digitale - che consente di elevare la "compatibilità" ad "elevata probabilità" che la "lettura massiva di file" sia parte dell'attività di "copia massima di file". Affinché ciò sia possibile, gli eventi sentinella devono essere il più possibile vicini temporalmente ai momenti di lettura massiva di file.

3.6.1 Gli eventi sentinella digitali

tadati, eccetera. Tecnicamente, esistono sia strumenti software che hardware atti a realizzare immagini bit-stream di supporti informatici.
In tema di best practice, cfr. Luparia L., Ziccardi G., *Investigazione penale e tecnologia informatica. L'accertamento del reato tra progresso scientifico e garanzie fondamentali*, Giuffrè, 2007, pp. 103 ss., dove si analizzano alcune tra le linee guida, specialmente statunitensi, del settore.

[15] Il concetto di sigillo elettronico è stato introdotto nell'art. 260 c.p.p. dall'art. 8, comma 8, lettera a, della L. 48/2008.

[16] A proposito di autenticazione della prova informatica, cfr. Maioli C., "Dar voce alle prove: elementi di informatica forense", in *Crimine virtuale, minaccia reale*, a cura di Pozzi P., Masotti R. e Bozzetti M., FrancoAngeli, 2004, pp. 69 e ss. Per una corretta documentazione del processo di acquisizione delle prove va attentamente verbalizzata o addirittura filmata tutta la fase di analisi e di ricerca di esse in modo da poter giustificare con chiarezza ogni singola operazione eseguita. Per quanto riguarda l'autenticazione delle prove va dimostrato che essa è stata eseguita senza modificare o in qualche modo turbare il sistema e le prove stesse vanno autenticate e verificate temporalmente con opportuni programmi di utilità in modo da poter facilmente dimostrare in sede di giudizio che l'operazione di riproduzione delle prove è stata eseguita nei modi e nei tempi indicati.

Gli eventi sentinella digitali sono informazioni ricavabili dai dati presenti sul sistema oggetto di analisi. L'evento sentinella per eccellenza è la connessione di una periferica di archiviazione di memorizzazione usb, in gergo "un disco esterno": la connessione di un dispositivo usb lascia numerose tracce relative al momento di prima e di ultima connessione, ragion per cui minore è il numero di volte che un dispositivo usb si utilizza, migliori e più accurate sono le informazioni che possono essere rinvenute sul sistema analizzato.

Quando un dispositivo di memoria è connesso al sistema operativo Microsoft Windows attraverso una porta USB, il sistema ricerca i driver più appropriati per il suo corretto funzionamento attraverso il meccanismo chiamato Plug&Play[17]. Se il dispositivo connesso è sconosciuto, il sistema gli assegna un nuovo identificativo (Device ID), memorizzando l'informazione nella chiave di registro "HKEY LOCAL MACHINE\Software\Microsoft\Windows\CurrentVersion".[18]

Le informazioni sopra menzionate trovano riscontro non solo nel registro, ma anche nel file "setupapi.log", memorizzato nella cartella di sistema[19]: all'interno di esso è possibile rinvenire traccia di installazione di driver, service pack e hotfix, con un livello piuttosto elevato di dettaglio.[20]

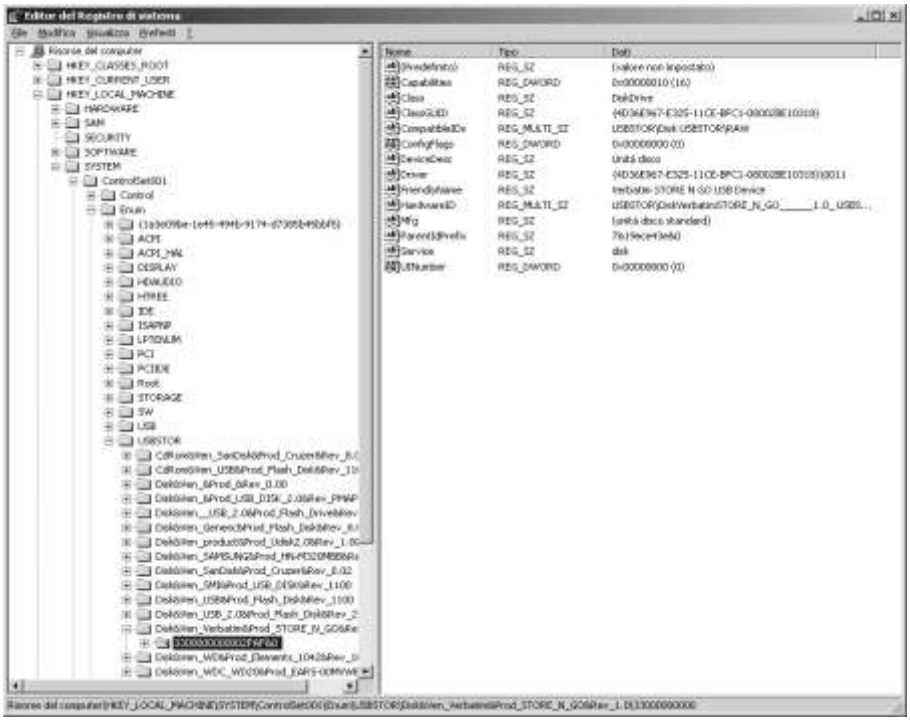
Di seguito si propone un esempio di dispositivo di memorizzazione esterno connesso in data 24/10/2012 alle ore 14:11.

[17] L'espressione Plug&Play (tradotto letteralmente significa "collega e usa") è usata in contesto tecnologico per far riferimento alle situazioni in cui un dispositivo hardware viene automaticamente riconosciuto dal sistema operativo all'atto del collegamento. Il sistema stesso si fa carico della procedura di installazione per consentire all'utente di utilizzare il device senza dover mettere in pratica una specifica procedura di installazione o di configurazione.

[18] Cfr. Carvey H., "The Windows registry as a forensic resource", in *Digital Investigation*, volume 2, issue 3, September 2005, pages 201-205. Cfr. Carvey H., Windows forensic analysis DVD Toolkit, 2nd ed., Syngress Publishing, 2009.

[19] La cartella di sistema è la cartella dove il sistema operativo memorizza i file necessari al suo corretto funzionamento; nel caso di Windows XP, di default la cartella di sistema è "C:\Windows".

[20] Cfr. Carvey H., Cory A., "Tracking USB storage: analysis of windows artifacts generated by USB storage devices", in *Digital Investigation*, volume 2, issue 2, June 2005, pages 94-100.



Il software USB Store Parser (USP)[21] è un tool a linea di comando che può essere eseguito su sistemi Windows, Unix e MacOSX senza necessità di installazione e che utilizza varie tecniche per estrarre ed analizzare diverse voci di registro e di file di log di Windows, creando un report riepilogativo relativo alle attività che si sono verificate su un computer che hanno riguardato dispositivi usb.

Il report riassume un elenco di dispositivi usb corredati da due timestamp relativi ai momenti di primo e di ultimo inserimento, oltre a vari altri metadati. Il software può estrarre le informazioni:

- da un sistema Windows avviato (da Windows XP a Windows 2008);
- da un'immagine forense di un sistema Windows;
- dal file di log setupapi e dai registri
- da un disco esterno che è stato montato
- da un disco virtuale VmWare.

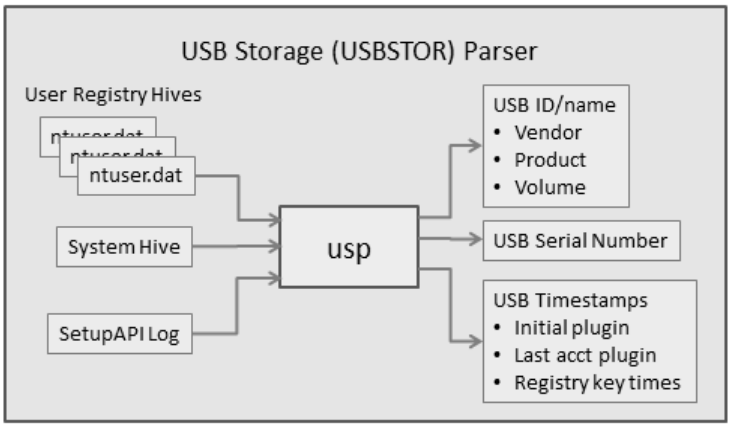


Figura 1 - Fonti e risultanze generate da USP (fonte http://www.tzworks.net/prototype_page.php?proto_id=13)

Il report generato può essere "dettagliato" (in forma testuale) oppure incolonnato (in formato csv). Riproponendo l'esempio precedente, l'output (parziale) di USB Store Parser è il seguente; alla riga 16 si può notare il dispositivo già evidenziato in precedenza.

[21] *http://www.tzworks.net/prototype_page.php?proto_id=13*.

device name	vid/pid date	vid/pid time (UTC)	install date	install time (local)	disk dev date
USB Device	09/12/2012	08:58:34.250	09/12/2012	10:58:35.000	09/12/2012
product DiskM2.0 USB Device	09/13/2012	11:58:39.146	09/13/2012	13:58:39.000	09/13/2012
USB 2.0 Flash Disk USB Device	09/18/2012	13:24:43.989	09/18/2012	15:24:44.000	09/18/2012
WDC WD10 KARS-00MVWB0 USB Device	09/24/2012	08:07:01.065			09/24/2012
WD Elements 1042 USB Device	09/24/2012	15:18:10.881	09/24/2012	17:18:14.000	09/24/2012
SanDisk Cruzer USB Device	10/05/2012	10:43:39.391	10/05/2012	12:43:39.000	10/05/2012
SanDisk Cruzer USB Device	10/05/2012	10:43:39.391	10/05/2012	12:43:43.000	
Generic Flash Disk USB Device	10/16/2012	12:47:58.526	10/16/2012	14:47:58.000	10/16/2012
SAMSUNG HN-M120MBB USB Device	10/16/2012	12:38:15.826	10/16/2012	14:38:18.000	10/16/2012
Verbatim STORE N GO USB Device	10/24/2012	12:11:17.770	10/24/2012	14:11:18.000	10/24/2012
USB 2.0 Flash Drive USB Device	10/29/2012	11:15:57.206	10/29/2012	12:15:57.000	10/29/2012
USB DISK 2.0 USB Device	10/30/2012	13:53:31.301	10/30/2012	14:53:32.000	10/30/2012
SMI USB DISK USB Device	11/09/2012	13:51:02.862	10/17/2012	12:19:01.000	11/09/2012
USB Flash Disk USB Device	11/14/2012	11:26:10.462	10/08/2012	10:45:25.000	
USB Flash Disk USB Device	11/14/2012	11:26:10.462	10/08/2012	10:45:29.000	11/14/2012

3.6.2 Gli eventi sentinella non digitali

In altri casi, gli eventi sentinella sono informazioni non reperibili dall'analisi del sistema informatico ma relative a situazioni del mondo reale: un esempio di evento sentinella non digitale è il momento in cui il sistema informatico viene restituito dal dipendente al datore di lavoro oppure la circostanza in cui il dipendente viene visto da altre persone compiere delle attività anomale.

Queste circostanze rappresentano delle ottime ragioni a sostegno della teoria che la lettura di file sia sintomo di copia di file.

3.7. *Correlazione fra eventi sentinella*

L'evento sentinella "lettura massiva di file" viene messo in stretta correlazione temporale con l'evento di collegamento di un dispositivo USB alla stazione di lavoro che, giova ricordare, viene tracciato dal sistema solo come prima e ultima connessione e per il quale è dunque possibile ipotizzare anche connessioni intermedie.

La stretta successione temporale di due eventi sentinella, ossia la coincidenza di due eventi necessari per la realizzazione di una condotta, diventa un rilevante elemento indiziario e quindi di grande importanza. Risulta evidente come informazioni aggiuntive di natura non informatica consentano di rafforzare il quadro indiziario: ad esempio, la rilevazione di una tale coincidenza di eventi che si verifica nello stesso periodo temporale da parte di altri operatori dello stesso gruppo di lavoro.

Di seguito si evidenzia un esempio di evento "inserimento di una chiave USB" posto in correlazione con l'evento "lettura di numerosi file in rapida sequenza temporale".

```
Dal pc normalmente utilizzato dal dipendente D1
risulta il seguente timestamp di connessione di
dispositivi USB: 24/10/2012 14:11
```

```
Dalla timeline dello stesso pc si evidenzia
quanto segue
                          […]
Wed Oct 24 2012 14:11:43 125279 .a. -/-rwxrwxrwx
C:/file_1.doc
                          […]
                         298579 .a. -/-rwxrwxrwx
C:/file_m.doc
Wed Oct 24 2012 14:11:44 479604 .a. -/-rwxrwxrwx
C:/file_m1.doc
                          […]
                          98410 .a. -/-rwxrwxrwx
C:/file_mn.doc
Wed Oct 24 2012 14:11:45 729615 .a. -/-rwxrwxrwx
C:/file_mn1.doc
                          […]
                          42403 .a. -/-rwxrwxrwx
C:/file_nmo.doc
                          […]
```

4. Conclusioni

Questo articolo si proponeva di illustrare come le timeline, unite a poche altre semplici informazioni, possono essere utilizzate per ricostruire dei fatti laddove non esiste una chiara prova di quanto accaduto, se non un insieme di eventi indiziari che consentono di disegnare uno scenario molto dettagliato.

Il caso proposto ha preso in esame unicamente gli eventi di accesso, modifica e creazione di file, attorno ai quali sono stati individuati gli eventi di connessione di dispositivi di memorizzazione USB.

Un'analisi più dettagliata può prendere in esame anche altri elementi quali, a mero titolo esemplificativo e non esaustivo, invio di email, cronologia di navigazione web, avanzamento nella scrittura di

documenti. Collocando sulla la linea del tempo queste altre informazioni è possibile definire in maniera più precisa quanto accaduto.

5. Bibliografia

- Carvey H., "The Windows registry as a forensic resource", in *Digital Investigation*, volume 2, issue 3, September 2005, pages 201-205.
- Carvey H., *Windows forensic analysis DVD Toolkit*, 2nd ed., Syngress Publishing, 2009.
- Carvey H., Cory A., "Tracking USB storage: analysis of windows artifacts generated by USB storage devices", in *Digital Investigation*, volume 2, issue 2, June 2005, pp. 94-100.
- Casey E., *Digital evidence and computer crime*, Academic Press, 2004.
- Chow K.P., Law F., Kwan M., Lai P, "The Rules of Time on NTFS File System", in *Second International Workshop on Systematic Approaches to Digital Forensic Engineering*, 2007, pp. 71-85.
- Costabile G., "Computer forensics e informatica investigativa alla luce della legge n. 48 del 2008", in *Ciberspazio e diritto*, volume 11, n. 3, 2010, pp. 499 e ss.
- Farmer D., Venema W., *Forensic discovery*. Addison Wesley, 2004.
- Grier J., "Detecting data theft using stochastic forensics", in *Digital Investigation*, volume 8, August 2011, pp. S71-S77.
- Koen R., Olivier M., "The Use of File Timestamps in Digital Forensics", in *ISSA 2008*, Johannesburg, South Africa, July 2008.
- Magri M., "Investigazioni digitali aziendali e industrial spies", in *Ciberspazio e diritto*, volume 11, n. 3, 2010, pp. 535-549.
- Maioli C., "Dar voce alle prove: elementi di informatica forense", in *Crimine virtuale, minaccia reale*, a cura di Pozzi P., Masotti R. e Bozzetti M., FrancoAngeli, 2004.
- Microsoft Corporation. Windows server 2003 Resource Kit Registry Reference: NtfsDisableLastAccessUpdate, *http://technet.microsoft.com/en-us/library/cc758569%28v=ws.10%29.aspx* [accessed 27/10/2014].

- Perri P. *Controllare l'internet sul luogo di lavoro*, 2006. *http://www.ictlex.net/?p=535* [ultimo accesso 27/10/2014].
- Willassen S.Y., "Timestamp evidence correlation by model based clock hypothesis testing", in *Proceedings of the 1st international conference on Forensic applications and techniques in telecommunications, information, and multimedia and workshop (e-Forensics '08)*, ICST, 2008.